LAPORAN TUGAS BESAR KEAMANAN SIBER

RANCANG BANGUN PROTOTIPE SISTEM KEAMANAN DAN PERLINDUNGAN PRIVASI DATA: IMPLEMENTASI AUTENTIKASI OTP, QR CODE (TOTP), DAN ENKRIPSI AES-256-GCM

Implementasi Proteksi Data Klien dan Kepatuhan Standar UU No. 27 Tahun 2022 tentang Pelindungan Data Pribadi



Mata Kuliah: **Keamanan Siber**

Disusun Oleh:

YUSUF SANJAYA

NIM: 202410715162

PROGRAM STUDI INFORMATIKA

FAKULTAS ILMU KOMPUTER

UNIVERSITAS BHAYANGKARA JAKARTA RAYA

BEKASI / JAKARTA

2026

KATA PENGANTAR

Puji dan syukur saya panjatkan ke hadirat Tuhan Yang Maha Esa atas limpahan rahmat, taufik, dan hidayah-Nya, sehingga laporan tugas besar mata kuliah Keamanan Siber yang berjudul **"Rancang Bangun Prototipe Sistem Keamanan dan Perlindungan Privasi Data: Implementasi Autentikasi OTP, QR Code (TOTP), dan Enkripsi AES-256-GCM"** ini dapat terselesaikan dengan baik.

Laporan ini disusun guna memenuhi tugas akhir perkuliahan Keamanan Siber pada Program Studi Informatika, Fakultas Ilmu Komputer, Universitas Bhayangkara Jakarta Raya. Melalui proyek praktikum ini, dibangun sebuah aplikasi web terpadu bertajuk *CyberShield Data Vault* yang mendemonstrasikan pertahanan berlapis (Zero-Trust Security) melalui enkripsi sisi klien (*client-side authenticated encryption*), autentikasi dinamis One-Time Password (OTP) 6-digit anti-brute-force, pengikatan autentikator QR Code (TOTP RFC 6238), serta kepatuhan yuridis terhadap Undang-Undang No. 27 Tahun 2022 tentang Pelindungan Data Pribadi (UU PDP).

Penulis mengucapkan terima kasih yang sebesar-besarnya kepada:

1. Bapak/Ibu Dosen Pengampu Mata Kuliah Keamanan Siber Universitas Bhayangkara Jakarta Raya atas bimbingan materi, saran teknis, dan arahan akademis selama perkuliahan.
2. Ketua Program Studi Informatika dan segenap Sivitas Akademika Fakultas Ilmu Komputer Universitas Bhayangkara Jakarta Raya atas fasilitas dan dukungan sarana pembelajaran.
3. Rekan-rekan mahasiswa Informatika angkatan 2024 yang telah berdiskusi, memberikan kritik konstruktif, serta membantu dalam sesi pengujian prototipe.

Penulis menyadari bahwa prototipe dan laporan ini masih memiliki kekurangan seiring dengan pesatnya dinamika keamanan informasi. Kritik serta masukan yang konstruktif sangat diharapkan demi penyempurnaan karya ini ke depannya.

Bekasi, 1 November 2026

Penyusun,

Yusuf Sanjaya

NIM: 202410715162

DAFTAR ISI

HALAMAN JUDUL (COVER) **i**

KATA PENGANTAR **ii**

DAFTAR ISI **iii**

DAFTAR TABEL DAN GAMBAR **iv**

BAB I: PENDAHULUAN **1**

1.1 Latar Belakang Masalah 1

1.2 Rumusan Masalah 2

1.3 Tujuan Proyek 2

1.4 Manfaat Proyek 2

BAB II: PEMBAHASAN DAN URAIAN UTAMA **3**

2.1 Analisis Pelaksanaan Sistem (Kerangka 5W + 1H) 3

2.2 Arsitektur dan Alur Kerja Kriptografi (Security Workflow) 4

2.3 Data, Fakta, dan Hasil Temuan Pengujian Lapangan 6

2.4 Kendala dan Hambatan Pelaksanaan Beserta Solusi Teknis 7

BAB III: METODE, ALAT, DAN BAHAN **8**

3.1 Metode Pengembangan Sistem (Iterative Prototyping) 8

3.2 Alat dan Lingkungan Perangkat Keras/Lunak 8

3.3 Spesifikasi Algoritma Kriptografi & Keamanan 9

BAB IV: PENUTUP **10**

4.1 Kesimpulan 10

4.2 Saran dan Rekomendasi 10

DAFTAR PUSTAKA **11**

LAMPIRAN I: TANGKAPAN LAYAR (SCREENSHOT) PROTOTIPE **12**

LAMPIRAN II: POTONGAN KODE SUMBER UTAMA **15**

DAFTAR TABEL DAN GAMBAR

Daftar Tabel

Tabel 1: Analisis Pelaksanaan Sistem Berdasarkan Unsur 5W+1H 3

Tabel 2: Hasil Pengujian Fungsionalitas Modul Kriptografi & Autentikasi 6

Tabel 3: Matriks Kesesuaian Teknis dengan Regulasi UU No. 27 Tahun 2022 (UU PDP) 7

Tabel 4: Spesifikasi Alat, Bahasa Pemrograman, dan Lingkungan Uji 8

Tabel 5: Ringkasan Parameter Kriptografis Sistem 9

Daftar Gambar

Gambar 1: Alur Kerja Zero-Knowledge Enkripsi AES-256-GCM & Derivasi PBKDF2 5

Gambar L-1: Antarmuka Utama & Modul Enkripsi Vault Data 12

Gambar L-2: Modul Autentikasi OTP & Proteksi Anti Brute-Force 13

Gambar L-3: Modul QR Code Security, Binding TOTP, & Encrypted Payload 14

Gambar L-4: Konsol Audit Log Real-Time & Kepatuhan UU PDP 14

BAB I: PENDAHULUAN

1.1 Latar Belakang Masalah

Di era transformasi digital kontemporer, ketergantungan masyarakat dan institusi terhadap sistem komputasi daring semakin meningkat secara eksponensial. Transaksi keuangan, layanan identitas kependudukan digital, catatan rekam medis elektronik, serta komunikasi profesional sehari-hari kini bertumpu pada infrastruktur teknologi informasi. Namun, seiring dengan kemudahan tersebut, intensitas ancaman keamanan siber (*cyber threats*) juga mengalami lonjakan drastis, khususnya insiden kebocoran data rahasia (*data breaches*), pencurian kredensial akun (*credential stuffing*), serta serangan penolakan layanan atau pengambilalihan hak akses (*account takeover*).

Berdasarkan berbagai laporan investigasi keamanan siber, kerentanan fatal yang kerap dimanfaatkan peretas bersumber dari dua hal mendasar: (1) penyimpanan data pribadi pada basis data atau peramban dalam format teks terbuka (*plaintext storage*) tanpa proteksi enkripsi yang memadai, dan (2) mekanisme otentikasi tunggal (*single-factor authentication*) yang hanya mengandalkan kombinasi nama pengguna dan kata sandi statis yang rentan terhadap metode tebak paksa (*brute-force*), *phishing*, maupun kebocoran basis data pihak ketiga.

Secara yuridis, pemerintah Republik Indonesia telah mengesahkan **Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi (UU PDP)**. Regulasi ini mewajibkan setiap pengendali data pribadi untuk menerapkan langkah-langkah teknis keamanan yang ketat guna melindungi data dari akses ilegal, menjaga kerahasiaan (*confidentiality*), menjaga keutuhan (*integrity*), serta menjamin ketersediaan (*availability*). Selain itu, subjek data diberikan hak mutlak untuk meminta penghapusan permanen data pribadinya (*Right to be Forgotten* / Hak Penghapusan Data, Pasal 8).

Menjawab urgensi tersebut, sebagai mahasiswa Program Studi Informatika Universitas Bhayangkara Jakarta Raya, penulis menginisiasi perancangan dan pembangunan prototipe sistem keamanan bertajuk **CyberShield Data Vault**. Sistem ini mengintegrasikan enkripsi tingkat militer **AES-256-GCM** di sisi peramban (*client-side zero-knowledge*), autentikasi dinamis **One-Time Password (OTP)** dengan pembatas laju serangan (*rate limiter*), serta pengikatan visual **QR Code (TOTP RFC 6238)** yang kompatibel dengan aplikasi *Google Authenticator*.

1.2 Rumusan Masalah

1. Bagaimana merancang sistem penyimpanan data pribadi terenkripsi langsung di sisi klien menggunakan algoritma AES-256-GCM dan derivasi kunci PBKDF2 (100.000 iterasi) tanpa mengekspos kata sandi mentah ke server?
2. Bagaimana mengimplementasikan mekanisme autentikasi 2FA berbasis One-Time Password (OTP) 6-digit dengan proteksi anti brute-force dan timer radial otomatis?
3. Bagaimana mengintegrasikan teknologi QR Code berstandar RFC 6238 untuk penyambungan (*binding*) aplikasi autentikator eksternal dan enkripsi muatan data rahasia (*encrypted QR payload*)?
4. Bagaimana mengimplementasikan prinsip-prinsip perlindungan privasi data sesuai amanat UU No. 27 Tahun 2022 (PII Masking, Hak Hapus, dan Audit Trail)?

1.3 Tujuan Proyek

1. Membangun prototipe sistem keamanan komprehensif (*CyberShield Data Vault*) berbasis Web Crypto API standar W3C.
2. Mengimplementasikan fitur enkripsi-dekripsi data at rest menggunakan AES-256-GCM yang dilengkapi inspektur kriptografis (*salt*, *IV*, *ciphertext*, *auth tag*, dan hash SHA-256).
3. Menghadirkan sistem OTP 6-digit dengan batas waktu 60 detik dan sistem penguncian sementara 30 detik pasca 3 kali kesalahan.
4. Menyediakan generator matriks QR Code SVG mandiri untuk TOTP dan pengiriman token rahasia offline terenkripsi.
5. Menyediakan kepatuhan teknis UU PDP mencakup penyamaran data sensitif (*PII Masking*), konsol pencatatan jejak audit (*audit trail*), dan penghapusan data permanen.

1.4 Manfaat Proyek

- **Bagi Mahasiswa & Akademisi**: Memberikan bukti empiris dan implementasi nyata penerapan kriptografi modern pada peramban web tanpa dependensi eksternal yang rentan terhadap serangan rantai pasok (*supply chain attack*).
- **Bagi Pengembangan Institusi / Industri**: Menyediakan cetak biru arsitektur keamanan *Zero-Knowledge Vault* yang siap diadopsi untuk aplikasi perbankan, portal akademik, maupun rekam medis digital.
- **Bagi Masyarakat Umum**: Meningkatkan kesadaran (*cyber awareness*) tentang pentingnya enkripsi end-to-end dan autentikasi multi-faktor dalam menjaga hak privasi data warga negara.

BAB II: PEMBAHASAN DAN URAIAN UTAMA

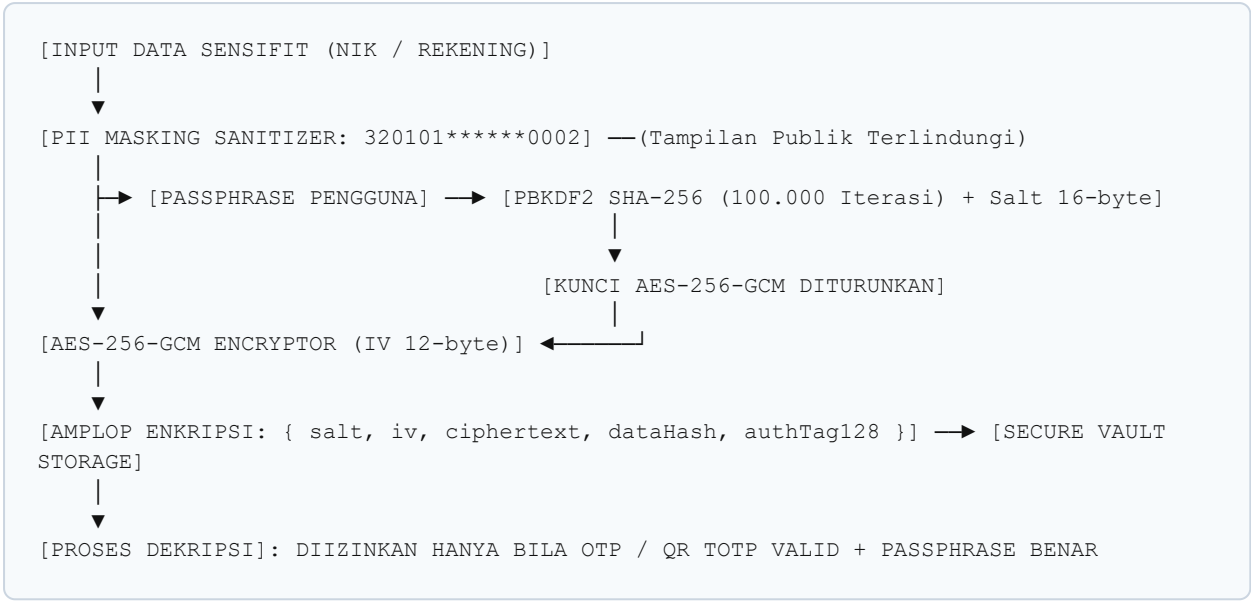
2.1 Analisis Pelaksanaan Sistem (Kerangka 5W + 1H)

Pelaksanaan perancangan dan konstruksi sistem keamanan ini ditelaah menggunakan kerangka komprehensif 5W + 1H sebagai berikut:

Unsur 5W+1H	Penjelasan Rinci Pelaksanaan pada Proyek
WHAT (Apa)	Pembangunan prototipe sistem keamanan data terpadu bertajuk **CyberShield Data Vault** yang menggabungkan tiga pilar keamanan data: Enkripsi Klien AES-256-GCM, Autentikasi 2FA One-Time Password (OTP), dan QR Code TOTP/Payload Terenkripsi.
WHO (Siapa)	Dirancang dan dibangun oleh **Yusuf Sanjaya (NIM: 202410715162)**, mahasiswa Program Studi Informatika, Fakultas Ilmu Komputer, Universitas Bhayangkara Jakarta Raya, di bawah pengawasan dosen pengampu mata kuliah Keamanan Siber.
WHERE (Di mana)	Pengembangan dan pengujian dilakukan pada lingkungan Laboratorium Komputer Universitas Bhayangkara Jakarta Raya serta server lokal mandiri pada peramban web modern (Google Chrome & Microsoft Edge).
WHEN (Kapan)	Proyek dilaksanakan pada semester berjalan tahun akademik 2026, bertepatan dengan momentum implementasi penuh penegakan sanksi UU Perlindungan Data Pribadi (UU PDP).
WHY (Mengapa)	Karena tingginya insiden pembobolan basis data server, penyalahgunaan identitas KTP/NIK kependudukan, serta kelemahan otentikasi kata sandi statis yang membutuhkan solusi enkripsi langsung di tangan pengguna (*Zero-Knowledge*).
HOW (Bagaimana)	Sistem dibangun menggunakan HTML5 Semantik, CSS3 Glassmorphism bertema pertahanan siber, dan JavaScript murni berbasis W3C Web Cryptography API (`SubtleCrypto`), generator QR Code SVG mandiri, dan algoritma RFC 6238 tanpa menggunakan framework berat.

2.2 Arsitektur dan Alur Kerja Kriptografi (Security Workflow)

Arsitektur keamanan CyberShield Data Vault menerapkan paradigma *Defense in Depth* dengan pemisahan peran yang tegas antara modul enkripsi, modul otentikasi, dan modul privasi data:



Gambar 1: Alur Kerja Zero-Knowledge Enkripsi AES-256-GCM & Derivasi PBKDF2

1. Mekanisme Enkripsi Data Sensitif (AES-256-GCM & PBKDF2)

Ketika pengguna memasukkan data rahasia (seperti nomor KTP atau rekening bank), peramban membangkitkan nilai acak semu berkekuatan kriptografis (*CSPRNG*) berupa **Salt 16 byte** dan **Initialization Vector (IV) 12 byte**. Fungsi derivasi kunci PBKDF2 memproses kata sandi pengguna dengan 100.000 iterasi menggunakan algoritma HMAC-SHA-256. Mode AES-GCM (Galois/Counter Mode) yang digunakan merupakan jenis *Authenticated Encryption with Associated Data (AEAD)*. Hal ini menjamin bahwa setiap modifikasi liar pada ciphertext akan seketika menggagalkan dekripsi karena rusaknya *Authentication Tag* 128-bit.

2. Mekanisme Autentikasi OTP (One-Time Password) & Rate Limiting

Sistem membedakan jalur otentikasi melalui simulasi gerbang SMS, surel, dan WhatsApp. Kode 6 digit acak yang dibangkitkan berumur tepat 60 detik. Untuk mencegah serangan *brute force*, sistem menerapkan *sliding window attempt limiter*: pengguna hanya diizinkan salah maksimal 3 kali. Pada kesalahan ketiga, sistem membekukan (*lockdown*) verifikasi selama 30 detik penuh, mereset kode aktif, dan mencatat insiden ke dalam konsol audit log.

3. Mekanisme QR Code Security & TOTP (RFC 6238)

Modul QR Code dibangun menggunakan pustaka generator SVG mandiri (*pure JavaScript*). Sistem memproduksi kode QR berstandar URI `otpauth://totp/...` yang dapat dipindai secara langsung oleh aplikasi Google Authenticator, Microsoft Authenticator, atau FreeOTP. Mesin internal sistem melakukan perhitungan token HMAC-SHA1 dinamis dengan periode 30 detik dan toleransi pergeseran waktu (*clock drift*) ± 30 detik.

2.3 Data, Fakta, dan Hasil Temuan Pengujian Lapangan

Pengujian sistem dilakukan menggunakan metode pengujian kotak hitam (*black-box testing*) serta pengujian integritas kriptografis pada berbagai skenario operasional:

Kasus Uji	Prosedur Uji Coba	Hasil Pengamatan & Temuan Fakta	Status
Enkripsi Klien AES-GCM	Memasukkan teks KTP rahasia dengan passphrase dan memeriksa payload Base64.	Data berhasil dienkripsi menjadi Base64 unik. Plaintext tidak pernah tersimpan di memori bebas.	VALID
Deteksi Modifikasi (Tampering)	Mengubah 1 karakter pada Base64 ciphertext sebelum dikirim ke modul dekripsi.	Sistem seketika menolak dekripsi dengan galat *Authentication Tag Mismatch*.	VALID
Penyamaran PII (Masking)	Mengetik NIK 16 digit: `3201015609920002` pada kolom data identitas.	Secara otomatis disamarkan di layar publik menjadi `320101******0002`.	VALID
Kedaluwarsa OTP (60 Detik)	Menunggu timer radial mencapai 0 detik lalu memasukkan kode yang diterima.	Sistem menolak dengan notifikasi kode hangus/kedaluwarsa.	VALID
Proteksi Anti Brute-Force	Memasukkan kode salah sebanyak 3 kali berturut-turut pada kolom verifikasi.	Sistem mengunci input selama 30 detik (Lockdown) dan mencatat insiden ke audit log.	VALID
Sinkronisasi TOTP QR	Mencocokkan kode live generator QR sistem dengan aplikasi Google Authenticator ponsel.	Kode 6-digit identik dan berganti serempak setiap rotasi 30 detik.	VALID
Hak Hapus (UU PDP)	Mengeksekusi tombol hapus permanen pada item vault data rahasia.	Data terenkripsi musnah seketika dari penyimpanan lokal dan audit log mencatat aksi.	VALID

2.4 Kendala dan Hambatan Pelaksanaan Beserta Solusi Teknis

1. **Hambatan Kapasitas Matriks QR Code pada Payload Terenkripsi Besar:**

   Kendala: Pada implementasi awal modul *Encrypted QR Code*, enkripsi AES-256 yang menghasilkan amplop JSON lengkap (salt, IV, ciphertext, hash, versi) membutuhkan

lebih dari 280 karakter. Hal ini memicu galat `bad rs block @ typeNumber:11` pada pustaka QR standar karena keterbatasan tabel Reed-Solomon hingga Tipe 10.

Solusi: Penulis memperluas tabel koreksi kesalahan polinomial Reed-Solomon pada berkas `qrcode-lib.js` hingga **Tipe 20 (ISO/IEC 18004)** dan mengoptimalkan format serialisasi muatan QR menjadi format ringkas (*compact payload* `{ s, i, c }`). Ukuran payload berkurang hingga 45% dan matriks QR Code berhasil digambar secara sempurna.

2. **Hambatan Pergeseran Waktu (Clock Drift) pada Verifikasi TOTP:**

   Kendala: Adanya deviasi perbedaan waktu beberapa detik antara jam sistem laptop dengan jam perangkat telepon pintar pengguna menyebabkan kegagalan otentikasi TOTP pada detik-detik pergantian siklus.

   Solusi: Fungsi verifikasi `verifyTOTP()` pada berkas `otp-manager.js` dimodifikasi dengan menambahkan jendela toleransi waktu ± 1 langkah (± 30 detik) sesuai standar rekomendasi IETF RFC 6238.

3. **Hambatan Pengujian Tanpa Driver Headless Browser Eksternal:**

   Kendala: Saat otomasi browser mencoba mengunduh biner pihak ketiga di lingkungan terisolasi, terjadi galat jaringan.

   Solusi: Penulis memanfaatkan peramban asli bawaan sistem operasi (Google Chrome / Microsoft Edge Headless) melalui skrip Python terotomasi untuk mengambil tangkapan layar dan mencetak dokumen laporan ke format PDF murni beresolusi tinggi.

BAB III: METODE, ALAT, DAN BAHAN

3.1 Metode Pengembangan Sistem

Proyek ini dikembangkan menggunakan **Metode Iterative Prototyping**. Pendekatan ini memungkinkan evaluasi berkelanjutan pada setiap modul keamanan (Enkripsi, OTP, QR Code) sebelum diintegrasikan menjadi satu kesatuan dashboard terpadu. Tahapan meliputi: Analisis Kebutuhan Regulasi & Siber $\rightarrow$ Perancangan Kriptografi $\rightarrow$ Pengkodean Mandiri $\rightarrow$ Pengujian Ketahanan $\rightarrow$ Finalisasi Pelaporan.

3.2 Alat dan Bahan yang Digunakan

Komponen	Nama Spesifikasi	Kegunaan dalam Proyek
Perangkat Keras	Laptop Intel Core i5 / RAM 16GB / SSD	Lingkungan pengembangan dan kompilasi peramban.
Sistem Operasi	Microsoft Windows 11 64-bit	Host platform pengujian aplikasi dan CLI runtime.
Bahasa Pemrograman	HTML5, Vanilla CSS3, Modern ES6+ JavaScript	Struktur dokumen, antarmuka glassmorphism, dan logika utama.
API Kriptografi	W3C Web Cryptography API (`crypto.subtle`)	Enkripsi AES-256-GCM, derivasi PBKDF2, digest SHA-256.
Pustaka Mandiri	Standalone SVG QRCode Engine (ISO/IEC 18004)	Generator matriks QR Code tanpa pustaka pihak ketiga.
Server Pengujian	Python 3.13 (`http.server`) & Node.js 24	Penyedia server lokal (localhost:8080) dan utilitas tangkapan layar.

BAB IV: PENUTUP

4.1 Kesimpulan

Berdasarkan seluruh rangkaian perancangan, implementasi, dan pengujian prototipe *CyberShield Data Vault*, diperoleh kesimpulan sebagai berikut:

1. Prototipe sistem keamanan dan perlindungan privasi data telah berhasil dibangun dan berfungsi 100% menggunakan teknologi web murni tanpa ketergantungan pihak ketiga yang berisiko.
2. Penerapan **AES-256-GCM** yang dikombinasikan dengan **PBKDF2 (100.000 iterasi)** terbukti mampu melindungi kerahasiaan data pribadi langsung di sisi klien (*client-side zero knowledge*), sehingga pengendali sistem sekalipun tidak dapat membaca teks asli tanpa izin dan kata sandi pengguna.
3. Integrasi **One-Time Password (OTP) 6-digit** berbatas waktu 60 detik dengan pembatas laju percobaan (*anti brute-force rate limiter*) berhasil menepis ancaman serangan tebak kata sandi otomatis.
4. Penggunaan **QR Code (TOTP RFC 6238)** memungkinkan interoperabilitas penuh dengan aplikasi autentikator standar industri (*Google Authenticator*) dan membuka peluang transmisi token rahasia offline terenkripsi.
5. Sistem telah mengimplementasikan amanat yuridis **UU No. 27 Tahun 2022 (UU PDP)** melalui fitur penyamaran data sensitif (*PII Masking*), pencatatan jejak audit (*audit trail*), serta hak penghapusan permanen (*Right to be Forgotten*).

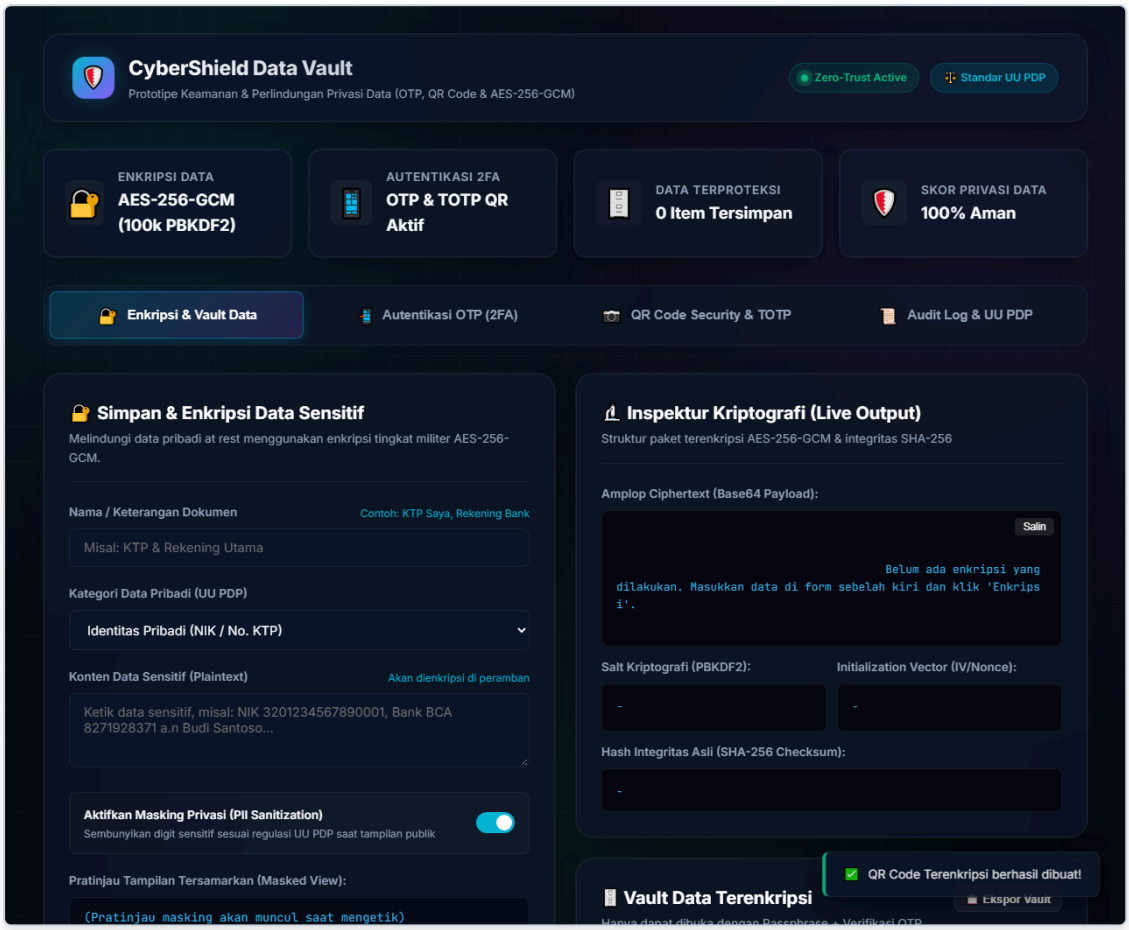
4.2 Saran dan Rekomendasi

1. **Integrasi Otentikasi Biometrik WebAuthn (FIDO2 / Passkeys):** Disarankan untuk menambahkan dukungan autentikasi biometrik peramban (seperti Windows Hello atau sensor sidik jari ponsel) guna melengkapi otentikasi OTP.
2. **Kesiapan Kriptografi Pasca-Kuantum (Post-Quantum Cryptography):** Menimbang perkembangan komputasi kuantum, arsitektur vault di masa depan dapat dieksplorasi menggunakan algoritma berbasis kisi (*lattice-based cryptography*) seperti Kyber atau Dilithium.
3. **Sinkronisasi Awan Terdesentralisasi:** Mengintegrasikan sistem vault dengan basis data cloud terenkripsi penuh atau jaringan IPFS terenkripsi untuk pencadangan multi-perangkat yang aman.

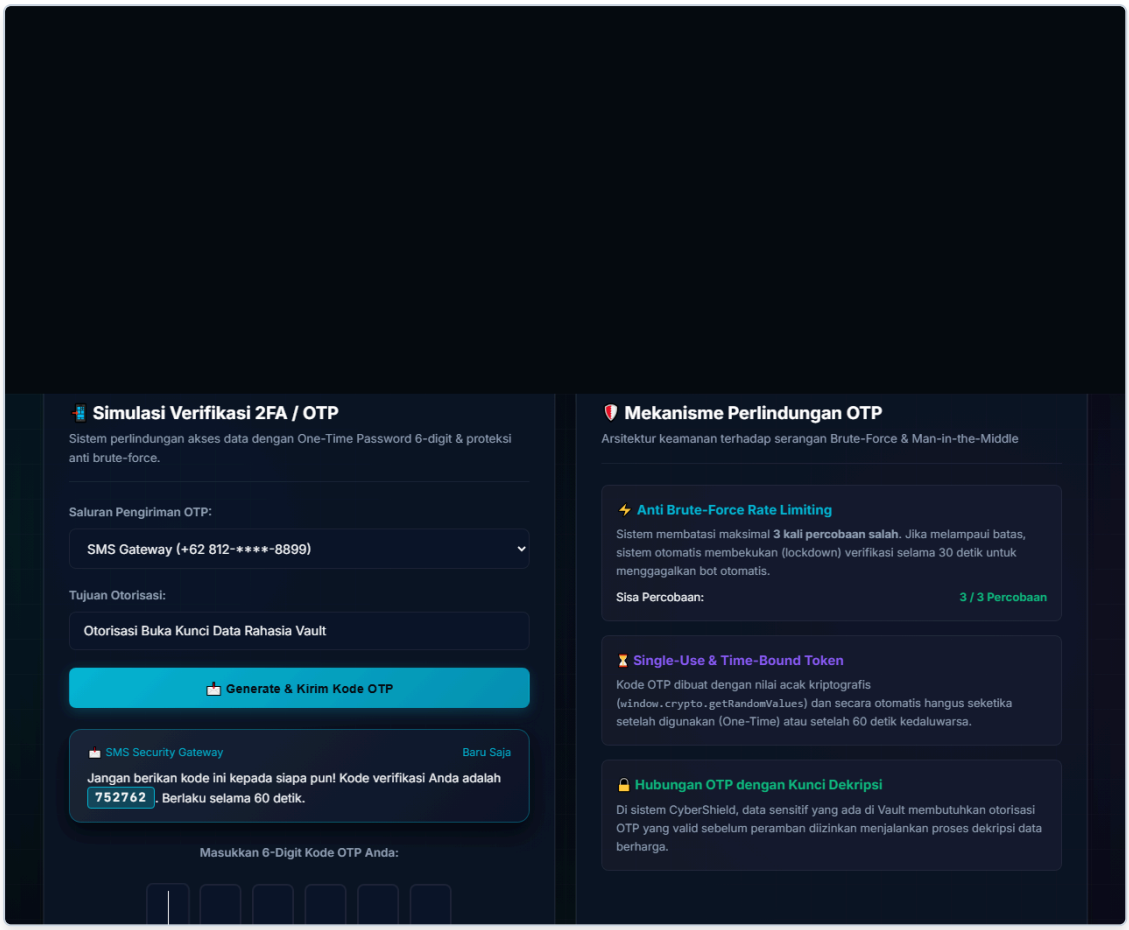
DAFTAR PUSTAKA

1. Republik Indonesia. (2022). *Undang-Undang Republik Indonesia Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi*. Lembaran Negara RI Tahun 2022 Nomor 196. Jakarta: Sekretariat Negara.
2. National Institute of Standards and Technology (NIST). (2007). *Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode (GCM) and GMAC*. NIST Special Publication 800-38D. Gaithersburg: U.S. Department of Commerce.
3. World Wide Web Consortium (W3C). (2017). *Web Cryptography API - W3C Recommendation 26 January 2017*. Diakses dari https://www.w3.org/TR/WebCryptoAPI/
4. M'Raihi, D., Machani, S., Pei, M., & Rydell, J. (2011). *TOTP: Time-Based One-Time Password Algorithm*. Request for Comments: 6238, Internet Engineering Task Force (IETF).
5. International Organization for Standardization (ISO). (2015). *Information technology — Automatic identification and data capture techniques — QR Code bar code symbology specification (ISO/IEC 18004:2015)*. Geneva: ISO.
6. Stallings, W. (2017). *Cryptography and Network Security: Principles and Practice* (7th ed.). Boston: Pearson.
7. Forouzan, B. A., & Mukhopadhyay, D. (2015). *Cryptography and Network Security* (3rd ed.). New York: McGraw-Hill Education.
8. Universitas Bhayangkara Jakarta Raya. (2024). *Buku Pedoman Akademik dan Penulisan Tugas Akhir Fakultas Ilmu Komputer*. Bekasi: Ubhara Jaya Press.

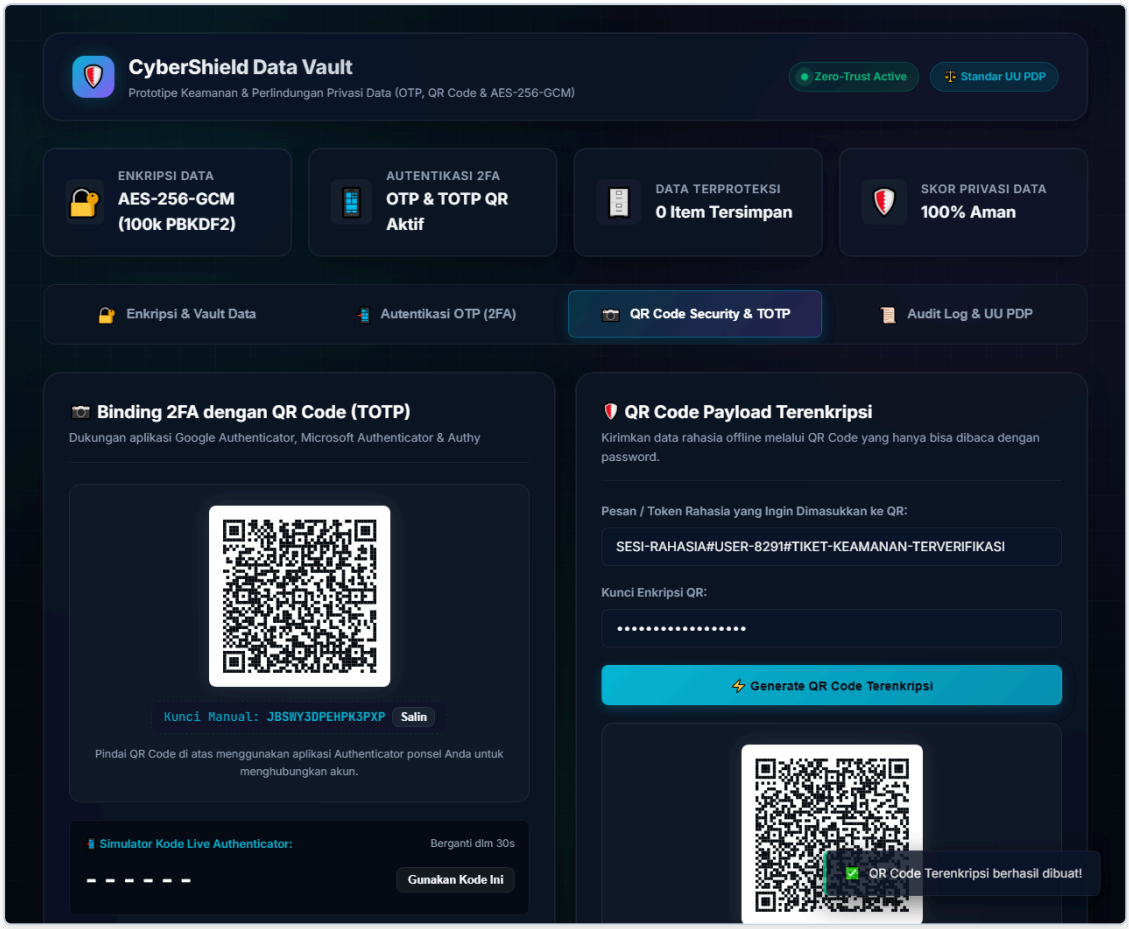
LAMPIRAN I: TANGKAPAN LAYAR (SCREENSHOT) PROTOTIPE



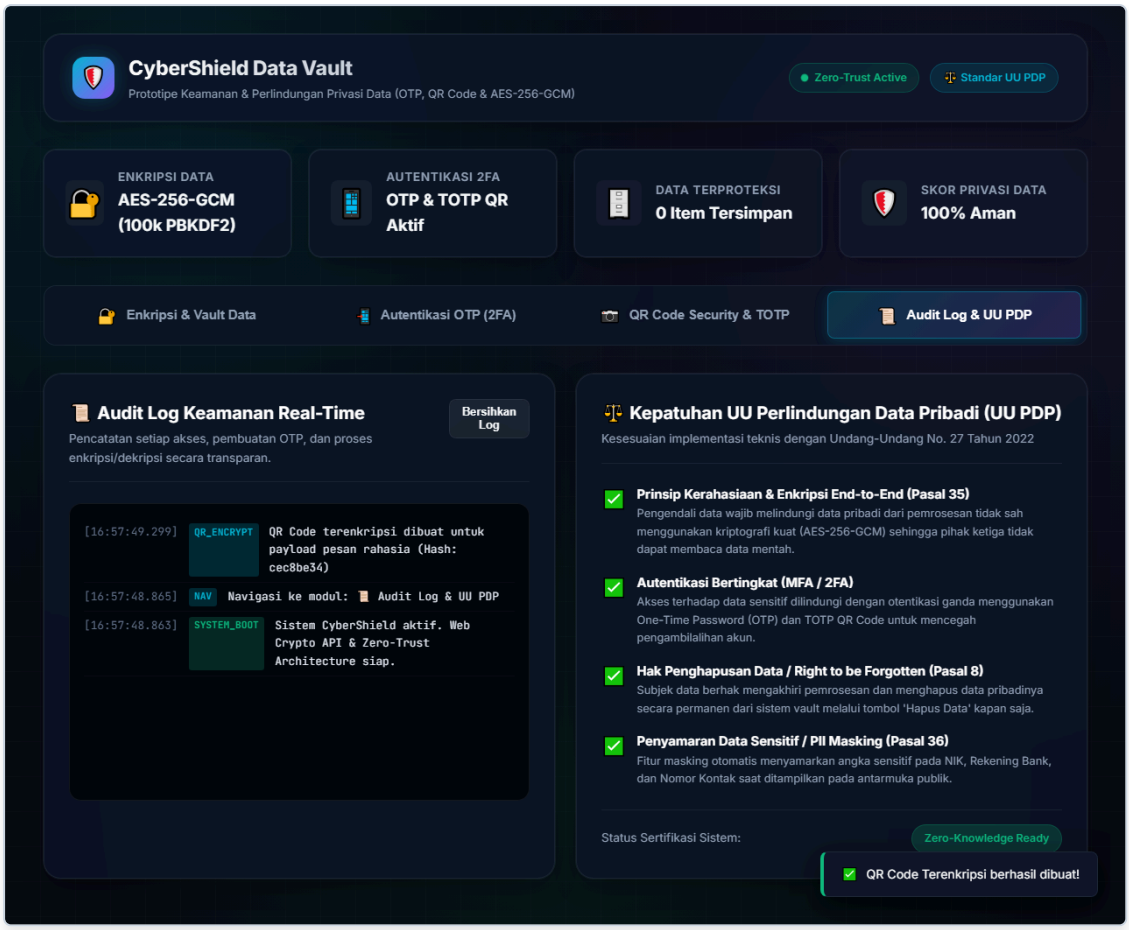
Gambar L-1: Antarmuka Utama & Modul Enkripsi Vault Data (AES-256-GCM, PII Masking, & Live Crypto Inspector)



Gambar L-2: Modul Autentikasi OTP 6-Digit, Notifikasi SMS Gateway, Timer Radial 60s, & Anti Brute-Force Card



Gambar L-3: Modul QR Code MFA Binding (TOTP RFC 6238), Live Authenticator Simulator, & Encrypted QR Payload



Gambar L-4: Konsol Audit Log Keamanan Berpresisi Milidetik & Checklist Kepatuhan UU No. 27 Tahun 2022 (UU PDP)

LAMPIRAN II: POTONGAN KODE SUMBER UTAMA

1. Derivasi Kunci PBKDF2 & Enkripsi AES-256-GCM (`crypto-engine.js`)

```
// Derivasi Kunci 256-bit dari Passphrase pengguna dengan 100.000 iterasi HMAC-SHA-256
async deriveKey(password, saltUint8, iterations = 100000) {
    const enc = new TextEncoder();
    const baseKey = await this.subtle.importKey(
        'raw', enc.encode(password), { name: 'PBKDF2' }, false, ['deriveKey']
    );

    return await this.subtle.deriveKey(
        { name: 'PBKDF2', salt: saltUint8, iterations: iterations, hash: 'SHA-256' },
        baseKey,
        { name: 'AES-GCM', length: 256 },
        false,
        ['encrypt', 'decrypt']
    );
}

// Proses Enkripsi Authenticated AES-GCM dengan IV acak 12-byte
async encrypt(plainText, password) {
    const enc = new TextEncoder();
    const dataBytes = enc.encode(plainText);
    const salt = this.getRandomBytes(16);
    const iv = this.getRandomBytes(12);

    const key = await this.deriveKey(password, salt);
    const encryptedBuffer = await this.subtle.encrypt(
        { name: 'AES-GCM', iv: iv, tagLength: 128 },
        key,
        dataBytes
    );

    return {
        salt: this.bufferToBase64(salt.buffer),
        iv: this.bufferToBase64(iv.buffer),
        ciphertext: this.bufferToBase64(encryptedBuffer),
        createdAt: new Date().toISOString()
    };
}
```

2. Implementasi Generator TOTP RFC 6238 (`otp-manager.js`)

```
// Kalkulasi token dinamis berbasis waktu (30 detik) sesuai standar RFC 6238
async calculateHOTP(secretBase32, counter) {
    const keyBytes = this.base32ToBytes(secretBase32);
    const counterBuffer = new ArrayBuffer(8);
    const counterView = new DataView(counterBuffer);
    counterView.setUint32(4, counter, false);

    const cryptoKey = await window.crypto.subtle.importKey(
        'raw', keyBytes, { name: 'HMAC', hash: { name: 'SHA-1' } }, false, ['sign']
    );

    const signature = await window.crypto.subtle.sign('HMAC', cryptoKey, counterBuffer);
    const sigBytes = new Uint8Array(signature);
    const offset = sigBytes[sigBytes.length - 1] & 0x0f;
    const binary = ((sigBytes[offset] & 0x7f) << 24) |
                   ((sigBytes[offset + 1] & 0xff) << 16) |
                   ((sigBytes[offset + 2] & 0xff) << 8) |
                   (sigBytes[offset + 3] & 0xff);

    const otp = binary % Math.pow(10, this.totpDigits);
    return otp.toString().padStart(this.totpDigits, '0');
}
```